T&T COMPUTER

BÁO CÁO RÀ SOÁT DỰ ÁN

Đối chiếu yêu cầu 18 Use Case với mã nguồn hiện tại

Ngày rà soát: 11/11/2026
Tài liệu yêu cầu: **NOTE/LaTex_Document/Nhap/BanMoi.pdf**
Mẫu trình bày: **NOTE/BAOCAO24-10-2026.pdf**

> **Phạm vi:** kiểm tra tĩnh toàn bộ mã nguồn và cấu hình của dự án, loại trừ nội dung thư mục **NOTE** khỏi đối tượng đánh giá. Chỉ đọc hai PDF được chỉ định để làm đầu vào. Không sửa mã nguồn, không kết nối hoặc ghi dữ liệu cơ sở dữ liệu, không chạy ứng dụng.

7	7	4
Use Case có chức năng cốt lõi	Use Case mới đáp ứng một phần	Use Case chưa có bằng chứng triển khai

> **Nhận định chính.** So với mẫu tháng 10, mã nguồn đã bổ sung đáng kể phần quản trị danh mục/sản phẩm, kho, quản lý nhân viên và thống kê. Phần mua hàng hiện vận hành theo hướng COD; quy trình xử lý đơn sau khi tạo, tích hợp cổng thanh toán và chương trình khuyến mại/voucher vẫn chưa khép kín.

Mức “có chức năng cốt lõi” nghĩa là tìm thấy luồng chính trong mã nguồn, không xác nhận đã chạy đúng trong môi trường thực tế. UC được đánh giá nghiêm theo các yêu cầu chi tiết của tài liệu.

1. Phạm vi và cấu trúc thực tế

Ứng dụng là website bán máy tính/linh kiện theo kiến trúc PHP MVC đơn giản: `public/index.php` nạp cấu hình và session, `routes/web.php` ánh xạ URL, controller xử lý yêu cầu, model truy vấn PDO và view dựng giao diện. Có 13 controller, 6 model, các trang khách hàng/quản trị, CSS/JavaScript và khoảng 120 ảnh sản phẩm.

Khu vực	Thành phần thấy trong source	Đánh giá
Khách hàng	Trang chủ, danh mục/sản phẩm, đăng ký/đăng nhập, hồ sơ, giỏ hàng, đặt COD, địa chỉ giao, xem và hủy đơn.	Các luồng mua hàng chính đã hình thành.
Quản trị	Dashboard; quản lý sản phẩm/danh mục; quản lý tài khoản nhân viên; cập nhật kho và lịch sử; thống kê doanh thu.	Đã có thêm nhiều màn hình so với báo cáo mẫu.
Thiếu theo vai trò	Không thấy route/controller cho nhân viên xác nhận, đóng gói, giao hàng hoặc xử lý đơn thất bại.	Quản lý đơn chỉ ở phía khách: xem và hủy khi chờ xác nhận.
Cơ sở dữ liệu	Ngoài NOTE chỉ có hai migration: thêm địa chỉ giao hàng (06/11) và thêm trạng thái danh mục (08/11). Không có file schema/seed đầy đủ.	Không thể xác nhận cấu trúc DB thực tế hoặc khả năng cài mới chỉ từ source được phép rà soát.

Điểm khớp thiết kế

- Các route ghi dữ liệu chủ yếu dùng POST; luồng đăng nhập, giỏ hàng, hồ sơ và quản trị có kiểm tra CSRF.
- Truy vấn dữ liệu dùng PDO và tham số hóa ở các thao tác thông thường.
- Đặt đơn kiểm tra giá/tồn trong transaction, khóa các dòng liên quan và ghi lịch sử xuất kho; hủy đơn chờ xác nhận thì hoàn số lượng.
- Quản trị kiểm tra lại vai trò/trạng thái tài khoản từ DB; người dùng thường chỉ xem/hủy đơn thuộc tài khoản của mình.

Điểm lệch kiến trúc / triển khai

- `config/app.php` bật `debug=true`; cần tắt ở môi trường triển khai.
- `public/index.php` đặt cứng base path, trong khi cấu hình cũng có `base_url`; đổi VirtualHost/thư mục có thể làm URL sai.
- Không thấy bộ schema chuẩn để tạo mới; migration danh mục dùng `ALTER TABLE ... ADD COLUMN` không có kiểm tra trước nên chạy lặp sẽ lỗi.
- Model `Cart::getItems()` có tác dụng ghi tổng tiền và đảm bảo tạo giỏ, dù được gọi khi đọc trang.

Nguồn kiểm tra chính: routes/web.php; public/index.php; app/Core; app/Controllers; app/Models; config; database/migrations.

2. Đối chiếu Use Case (UC01–UC09)

UC	Yêu cầu chính	Trạng thái	Đối chiếu mã nguồn và khoảng trống
01	Đăng ký; kiểm tra dữ liệu và định danh trùng.	**Một phần**	Có form, xác thực dữ liệu, kiểm tra username/email và tạo tài khoản băm mật khẩu. Không có schema ngoài NOTE để xác nhận ràng buộc UNIQUE chống đăng ký đồng thời.
02	Đăng nhập tài khoản đang hoạt động; phân quyền theo vai trò.	**Cốt lõi có**	Có password_verify, kiểm tra trạng thái, tái tạo session ID, CSRF và chuyển hướng admin/nhân viên/khách. Admin được đối chiếu lại trạng thái ở DB.
03	Xem, tìm, lọc sản phẩm theo danh mục, giá, hãng/thuộc tính.	**Một phần**	Có tìm theo tên, lọc danh mục, sắp xếp giá/tên; ẩn sản phẩm/danh mục ngừng kinh doanh. Chưa thấy lọc khoảng giá, hãng hoặc thuộc tính kỹ thuật.
04	Thêm, sửa số lượng, xóa sản phẩm trong giỏ.	**Cốt lõi có**	Giỏ gắn tài khoản; kiểm tra trạng thái và tồn trong luồng thêm/cập nhật; thao tác ghi có POST và CSRF. GET xem giỏ vẫn có thể tạo giỏ/cập nhật tổng tiền.
05	Tạo đơn từ giỏ; kiểm tra thông tin, giá, tồn và giữ kho.	**Cốt lõi có**	Checkout nhận COD, kiểm tra người nhận/số điện thoại/địa chỉ; Order tính lại giá, khóa và trừ kho trong transaction, tạo chi tiết và lịch sử kho. Không có voucher/giá khuyến mại.
06	COD và thanh toán trực tuyến; callback hợp lệ, lỗi và thử lại.	**Một phần**	Chỉ có COD, tạo đơn ở trạng thái chưa thanh toán. Không thấy tích hợp cổng, giao dịch, callback/webhook, thử lại hoặc cập nhật paid.
07	Theo dõi và hủy đơn theo chuyển trạng thái quy định.	**Một phần**	Khách xem danh sách/chi tiết và hủy khi “Chờ xác nhận”; hủy khóa đơn, hoàn kho và ghi lịch sử. Chưa có luồng chuẩn bị/giao/hoàn thành/giao thất bại/hoàn hàng.
08	Quản lý hồ sơ và mật khẩu.	**Một phần**	Có xem/sửa hồ sơ và đổi mật khẩu với mật khẩu hiện tại, POST/CSRF. Chưa có bằng chứng bao phủ đầy đủ mọi quy tắc/phạm vi vai trò của tài liệu.
09	Nhân viên/quản trị tiếp nhận và xử lý đơn.	**Chưa triển khai**	Không có route quản trị đơn hoặc thao tác chuyển trạng thái. OrderController chỉ cung cấp đơn hàng riêng của khách và hủy đơn.

> **Luồng đơn hàng hiện có:** tạo COD ở trạng thái “Chờ xác nhận” → khách có thể hủy và hoàn kho. Các bước xử lý nội bộ được mô tả trong yêu cầu nhưng chưa có giao diện/route tương ứng.

3. Đối chiếu Use Case (UC10–UC18)

UC	Yêu cầu chính	Trạng thái	Đối chiếu mã nguồn và khoảng trống
10	Nhân viên tra cứu tồn; không tự điều chỉnh.	**Một phần**	Có trang xem tồn/lịch sử và cảnh báo tồn thấp, nhưng chỉ route quản trị; không thấy quyền/không gian tra cứu riêng cho nhân viên.
11	Quản trị thêm/sửa/ngừng bán sản phẩm.	**Cốt lõi có**	Có tìm/quản lý, tạo/sửa thông tin sản phẩm, đổi trạng thái; sản phẩm mới bắt đầu tồn bằng 0. Không xóa vật lý, phù hợp bảo toàn tham chiếu đơn đã tạo.
12	Quản trị danh mục; ngừng danh mục có liên kết.	**Cốt lõi có**	Có thêm/sửa tên/đổi trạng thái; danh mục ngừng kinh doanh bị loại khỏi danh sách bán. Chỉ xóa danh mục không còn sản phẩm liên kết.
13	Quản lý khách hàng và nhân viên, khóa/mở tài khoản.	**Một phần**	Màn hình hiện quản lý nhân viên: tạo/sửa/trạng thái, ngăn admin tự khóa mình. Không thấy màn hình tìm/quản lý/khóa tài khoản khách hàng theo yêu cầu.
14	Điều chỉnh/nhập kho có phân quyền và lịch sử.	**Cốt lõi có**	Admin có nhập/điều chỉnh kho trong transaction, khóa tồn, chặn âm, ghi actor và lịch sử. Hoàn kho khi giao thất bại thuộc luồng UC07 và hiện chưa có.
15	Thống kê theo thời gian; doanh thu chỉ từ đơn hoàn thành.	**Cốt lõi có**	Có lọc ngày, số đơn theo trạng thái, doanh thu và top sản phẩm từ đơn hoàn thành, cảnh báo tồn thấp. Chưa xác nhận kết quả thực tế do không truy cập DB/chạy ứng dụng.
16	Quản lý chương trình giảm giá.	**Chưa triển khai**	Không thấy module/route/model cho chiến dịch, thời hạn, điều kiện hoặc giá sau giảm.
17	Quản lý voucher.	**Chưa triển khai**	Không thấy CRUD voucher, mã, hạn dùng, hạn mức hay điều kiện áp dụng.
18	Áp dụng voucher khi đặt hàng.	**Chưa triển khai**	Checkout không nhận mã voucher; tổng tiền đơn được tính từ giá sản phẩm và số lượng.

Diễn giải mức hoàn thành

Cốt lõi có (7): UC02, UC04, UC05, UC11, UC12, UC14, UC15.

Một phần (7): UC01, UC03, UC06, UC07, UC08, UC10, UC13. **Chưa triển khai (4):** UC09, UC16–UC18. UC01 được xếp một phần vì chưa thể xác nhận ràng buộc duy nhất ở database.

Các mức phản ánh chức năng cốt lõi thấy trong source; không thay thế kiểm thử nghiệm thu. UC14 có nhập/điều chỉnh kho cho quản trị viên; quy trình hoàn kho khi giao thất bại được đánh giá ở UC07.

4. Quy tắc nghiệp vụ, dữ liệu và bảo vệ

Quy tắc đã thấy trong code

- Giá trị tổng đơn được tính phía máy chủ; không tin tổng tiền gửi từ trình duyệt.
- Đặt đơn dùng transaction và khóa dòng sản phẩm để tránh trừ vượt tồn; hủy đơn chỉ chấp nhận trạng thái chờ xác nhận và hoàn tồn trong transaction.
- Kho chặn số lượng đích âm, lưu chênh lệch và tài khoản thao tác.
- Quản trị được xác thực lại vai trò/trạng thái từ DB; route ghi có kiểm tra CSRF.
- Địa chỉ lưu theo chủ tài khoản; truy vấn lấy địa chỉ theo đúng khách hàng.
- View quản trị và nhiều view khách hàng escape dữ liệu HTML bằng htmlspecialchars.

Khoảng trống / rủi ro

Cao — thiếu schema cài đặt: không có database.sql hay schema khác ngoài NOTE; không thể tái lập DB, xác minh khóa ngoại/UNIQUE/CHECK hoặc khẳng định code khớp schema đang chạy.

Cao — tài khoản khách đã vô hiệu hóa: một số guard giỏ/đơn dựa vào session và vai trò; chưa thấy kiểm tra lại trạng thái tài khoản ở mỗi yêu cầu như guard quản trị.

Trung bình — migration trạng thái danh mục: ALTER TABLE không idempotent; cần quy trình phiên bản hóa và kiểm tra schema trước khi chạy lại.

Trung bình — trạng thái đơn: mã hiện tại chỉ tạo “Chờ xác nhận” và hủy; thiếu các trạng thái giao hàng trong quy trình yêu cầu, khiến UC09/07/15 bị giới hạn.

Giới hạn cần xác nhận

- Email/username được dò trùng ở tầng ứng dụng; do schema không có mặt trong phạm vi rà soát, chưa xác nhận ràng buộc UNIQUE phía DB.
- Migration địa chỉ tạo bảng có khóa ngoại NguoiDung; yêu cầu bảng cha phải tồn tại trước khi chạy.
- Migration danh mục cần chạy đúng một lần trên schema phù hợp; chưa có migration runner/ledger trong source.
- Thống kê đọc trạng thái “Hoàn thành”, nhưng code hiện chưa có luồng nào chuyển đơn sang trạng thái này; số liệu hoàn thành sẽ chỉ có ý nghĩa khi có quy trình xử lý đơn.
- Session khách chưa thấy thu hồi tức thời khi tài khoản bị khóa; cần xác minh tất cả controller được bảo vệ đồng nhất.
- Không chạy PHP lint, test tự động, trình duyệt, hoặc truy vấn MySQL; kết luận chỉ dựa trên đọc mã nguồn tĩnh.

Yếu tố ngoài phạm vi

Không đánh giá các tệp trong `NOTE`, dữ liệu MySQL cục bộ, triển khai Apache/PHP thực tế, quyền truy cập máy chủ, giao dịch thanh toán thật, hay tính đúng của nội dung từng ảnh sản phẩm. Hai PDF chỉ được dùng làm yêu cầu tham chiếu và mẫu trình bày.

> **Độ tin cậy:** cao với route/controller/model và các thao tác SQL thấy trực tiếp; trung bình với tính đầy đủ của schema và runtime vì không có schema chuẩn/không chạy ứng dụng.

5. Ưu tiên hoàn thiện

Ưu tiên 1 — bảo đảm có thể triển khai và vận hành an toàn

1. Bổ sung schema khởi tạo và dữ liệu seed phù hợp; thêm UNIQUE cho username/email, ràng buộc khóa ngoại/chỉ mục/trạng thái cần thiết. Viết quy trình migration có phiên bản và kiểm tra trước/sau khi áp dụng.

2. Tắt debug và display_errors trên môi trường triển khai; gom base path về một nguồn cấu hình; xác nhận cấu hình session/cookie HTTPS.

3. Kiểm tra trạng thái tài khoản/role cho mọi request đã đăng nhập, gồm khách hàng và nhân viên; thống nhất guard dùng chung.

Ưu tiên 2 — khép kín quy trình đơn

4. Tạo màn hình/route xử lý đơn cho nhân viên và quản trị; chỉ cho phép chuyển trạng thái theo máy trạng thái, ghi người thao tác và thời điểm.

5. Hoàn thiện giao thất bại/nhận hàng hoàn và hoàn kho đúng một lần; bổ sung trạng thái, lịch sử và kiểm soát cạnh tranh.

6. Chốt phạm vi thanh toán. Nếu giữ COD, sửa tiêu chí nghiệm thu/tài liệu cho nhất quán; nếu có online, triển khai giao dịch, xác minh chữ ký callback, idempotency, timeout và thử lại.

Ưu tiên 3 — hoàn thành phần thương mại

7. Bổ sung giảm giá/voucher từ mô hình dữ liệu đến kiểm tra điều kiện và tính lại ở server trong transaction đặt đơn.

8. Thêm lọc giá/hãng/thuộc tính cho UC03; quản lý tài khoản khách hàng cho UC13; cấp quyền tra cứu kho cho nhân viên theo UC10/14.

9. Chỉ số liệu đơn hoàn thành sau khi trạng thái hoàn thành được cập nhật qua quy trình thực tế; đối chiếu doanh thu với chính sách đơn hủy/hoàn.

6. Kết luận

So với mẫu rà soát ngày 24/10/2026, phần quản trị hiện đã được mở rộng: có quản lý sản phẩm và danh mục, cập nhật kho có lịch sử, quản lý nhân viên và trang thống kê. Luồng khách hàng cũng đã có lưu địa chỉ giao hàng và cơ chế khóa kho khi đặt/hủy đơn.

Đánh giá theo chức năng lõi: **7 UC có chức năng cốt lõi, 7 UC đáp ứng một phần, 4 UC chưa có bằng chứng triển khai**. Dự án phù hợp làm nền cho website bán hàng COD và quản trị cơ bản, nhưng chưa đạt đầy đủ tài liệu 18 UC: thiếu xử lý đơn nội bộ và các UC giảm giá/voucher; thanh toán online không có; schema khởi tạo ngoài NOTE cũng chưa được cung cấp.

Kết luận sử dụng: trước khi nghiệm thu hoặc triển khai, ưu tiên xác lập schema/migration chuẩn, tắt debug, bổ sung guard trạng thái tài khoản và hoàn thiện máy trạng thái đơn. Đồng thời thống nhất với tài liệu phạm vi COD hay tích hợp cổng thanh toán.